

TwinaForms ZAP ISV Response

Date: 2026-08-20

Package release context: TwinaForms managed package 0.14.0.1 , package version id 04tgL000000009FQAW .

Scope: OWASP ZAP Automation Framework requestor scans for public TwinaForms form hosting and AWS runtime endpoints. The official reports listed below are passive requestor evidence scans. Protected routes are intentionally scanned without bearer/JWT credentials to prove unauthenticated rejection. No active attack scan was run for this evidence packet.

Official reports to attach with this response:

- Report 01: published form page
- Report 02: prefill Lambda
- Report 03: submit Lambda
- Report 04: Salesforce backend Lambda
- Report 05: submission logs Lambda
- Report 06: admin API Cognito-protected Lambda
- Report 07: portable snapshots import/export backend routes

Finding Summary

No High-risk alert types were reported in the August 20, 2026 ZAP reports.

Alert types by report:

- 01-published-form-page.html : Content Security Policy (CSP) Header Not Set (Medium), Sub Resource Integrity Attribute Missing (Medium), Cross-Domain JavaScript Source File Inclusion (Low), Server Leaks Version Information via "Server" HTTP Response Header Field (Low), Information Disclosure - Sensitive Information in URL (Informational), Modern Web Application (Informational), Re-examine Cache-control Directives (Informational)
- 02-prefill-lambda.html : Cross-Domain Misconfiguration (Medium), Strict-Transport-Security Header Not Set (Low)
- 03-submit-lambda.html : Cross-Domain Misconfiguration (Medium), Strict-Transport-Security Header Not Set (Low)
- 04-salesforce-backend-lambda.html : Cross-Domain Misconfiguration (Medium), Strict-Transport-Security Header Not Set (Low), Re-examine Cache-control Directives (Informational)
- 05-submission-logs-lambda.html : Cross-Domain Misconfiguration (Medium), Strict-Transport-Security Header Not Set (Low)
- 06-admin-api-cognito.html : Strict-Transport-Security Header Not Set (Low)
- 07-portable-snapshots-import-export.html : Cross-Domain Misconfiguration (Medium), Strict-Transport-Security Header Not Set (Low)

Content Security Policy (CSP) Header Not Set

Classification: Not applicable to current trust boundary / informational browser-header note.

The published form is a static generated HTML page served from S3/CloudFront. The current response includes managed security headers such as `X-Content-Type-Options: nosniff` and `Strict-Transport-Security: max-age=31536000`, which are visible in the ZAP report evidence.

TwinaForms treats browser-rendered form content as the relevant risk area for this CSP finding. The Salesforce publisher encodes generated HTML values, escapes JavaScript string values, normalizes supported input types, and avoids appending configured custom JavaScript as raw trailing script markup. Runtime merged-document values are also escaped before they are inserted into generated browser HTML. These controls reduce XSS exposure in the generated page.

Generated customer forms can include optional browser features such as CAPTCHA, customer styling, external image resources, and customer-approved custom JavaScript. The CSP header finding is therefore evaluated as browser-header guidance for the generated public page, not as evidence of exposed Salesforce data, tokens, credentials, tenant secrets, or authentication bypass. Runtime prefill and submit operations are still validated server-side with the published form token and configured form policies.

Sub Resource Integrity Attribute Missing

Classification: Not applicable to current trust boundary / informational browser-resource note.

The published form can include external browser resources only for supported client-side form features. These resources are not used for authentication, authorization, tenant trust, Salesforce API access, or server-side policy enforcement.

Salesforce credentials, OAuth tokens, tenant bearer secrets, AWS secrets, and package signing secrets are never exposed to these browser resources. Server-side operations remain protected by TwinaForms runtime validation, publish-token checks, form-id checks, and configured tenant policies.

Cross-Domain JavaScript Source File Inclusion

Classification: Expected browser behavior for supported third-party services.

Published forms may load approved third-party browser resources, for example CAPTCHA provider scripts. These scripts are used for client-side form features only. They do not receive Salesforce credentials, tenant bearer secrets, AWS secrets, or OAuth refresh tokens.

Server-side operations remain controlled by the TwinaForms runtime, publish tokens, form id checks, and tenant policies.

Server Leaks Version Information via `Server` HTTP Response Header Field

Classification: Expected infrastructure header.

The response includes an AWS infrastructure `Server` header because the published form is hosted through AWS-managed infrastructure. This identifies the hosting service but does not expose application version numbers, source paths, credentials, tenant data, or Salesforce data.

Information Disclosure - Sensitive Information in URL

Classification: Expected test input and accepted product behavior for this demo form.

The tested URL intentionally includes `email=liam.carter@example.com` to exercise the public prefill flow. This is sample data and is not a password, OAuth token, API key, tenant secret, or AWS secret.

TwinaForms allows form administrators to configure prefill links. A lookup value such as an email address can be used when that is the intended form design. The browser cannot use that URL parameter to choose arbitrary Salesforce objects, fields, or queries. The prefill endpoint validates the published form token and rejects unexpected parameters.

For forms with more sensitive lookup values, the recommended form design is to avoid sensitive identifiers in URLs or use stronger verification before showing sensitive data.

Modern Web Application

Classification: Informational.

The published form is a JavaScript-enabled public web form. This is expected and does not indicate a vulnerability by itself.

Re-examine Cache-control Directives

Classification: Accepted operational behavior.

The published form uses conservative cache behavior so recently republished forms and setup changes are not hidden by stale browser or CDN content during customer onboarding and launch testing. The finding does not show credential exposure or access-control failure.

`02-prefill-lambda.html`

Cross-Domain Misconfiguration

Classification: Accepted runtime behavior.

The prefill Lambda accepts cross-origin browser calls because published forms are static pages hosted separately from the Lambda Function URL. The endpoint does not rely on cookies or browser credentials. It requires the per-form public publish token, validates the form id, rejects unexpected parameters, and returns only fields mapped by the form designer for that published form.

The current ZAP plan includes rejection cases for missing token, invalid token, and unexpected parameters.

Strict-Transport-Security Header Not Set

Classification: AWS-managed HTTPS endpoint behavior / informational browser-header note.

The Lambda Function URL is an AWS-managed HTTPS endpoint. Salesforce and browser traffic use HTTPS. The missing HSTS header is reported on the AWS-managed Lambda URL domain and is not evidence of plaintext transport.

`03-submit-lambda.html`

Cross-Domain Misconfiguration

Classification: Accepted runtime behavior.

The submit Lambda must accept browser calls from published TwinaForms forms. The endpoint does not use cookies for authentication. It validates the per-form publish token, form id, and configured submit policy before writing to Salesforce.

The current ZAP plan uses safe rejection cases and does not create Salesforce records.

Strict-Transport-Security Header Not Set

Classification: AWS-managed HTTPS endpoint behavior / informational browser-header note.

The endpoint is served over HTTPS. The missing HSTS header is reported on the AWS-managed Lambda URL domain and is not evidence of plaintext transport.

04-salesforce-backend-lambda.html

Cross-Domain Misconfiguration

Classification: Accepted behavior for this scan context.

Some backend responses include permissive CORS headers. CORS is not used as an access-control mechanism; protected routes require the tenant bearer secret used by Salesforce callouts. The ZAP plan intentionally sends missing-auth requests and verifies that protected routes reject unauthenticated access.

No tenant bearer secret is included in the report.

Strict-Transport-Security Header Not Set

Classification: AWS-managed HTTPS endpoint behavior / informational browser-header note.

The endpoint is HTTPS-only from the Salesforce package perspective. The missing HSTS header is reported on the AWS-managed Lambda URL domain and is not evidence of plaintext transport.

Re-examine Cache-control Directives

Classification: Informational.

The backend endpoint returns JSON operational responses. Caching is not used as an access control mechanism. Protected routes require tenant bearer authentication.

05-submission-logs-lambda.html

Cross-Domain Misconfiguration

Classification: Accepted behavior for this scan context.

The submission logs Lambda is called by Salesforce with tenant bearer authentication. The ZAP plan sends missing-auth requests and verifies that routes reject unauthenticated access. No tenant bearer secret is included in the report.

Strict-Transport-Security Header Not Set

Classification: AWS-managed HTTPS endpoint behavior / informational browser-header note.

The endpoint is served over HTTPS. The missing HSTS header is reported on the AWS-managed Lambda URL domain and is not evidence of plaintext transport.

06-admin-api-cognito.html

Strict-Transport-Security Header Not Set

Classification: AWS-managed HTTPS endpoint behavior / informational browser-header note.

The Admin API is protected by Cognito JWT validation. The ZAP plan sends requests without a Cognito token and verifies that the API rejects them with 401 Unauthorized .

The missing HSTS header is reported on the AWS-managed Lambda Function URL. The admin web console itself is hosted on admin.twinaforms.com and uses Cognito Hosted UI login. This finding does not show plaintext transport, exposed credentials, or authentication bypass.

07-portable-snapshots-import-export.html

Cross-Domain Misconfiguration

Classification: Accepted behavior for this scan context.

The portable snapshot import/export routes are backend package-to-AWS routes used for TwinaForms form portability. They are not public data APIs. They require the tenant bearer secret used by Salesforce callouts.

The ZAP plan intentionally sends requests to the snapshot save, list, and download routes without bearer credentials and verifies unauthenticated rejection with 401 Unauthorized :

- POST /portable-snapshots/latest
- GET /portable-snapshots
- GET /portable-snapshots/{sourceOrgId}/{globalFormKey}

CORS is not used as an access-control mechanism for these routes. The finding does not show public access to portable snapshot data, tenant secrets, Salesforce data, or credentials. No tenant bearer secret is included in the report.

Strict-Transport-Security Header Not Set

Classification: AWS-managed HTTPS endpoint behavior / informational browser-header note.

The portable snapshot routes are served over the AWS-managed HTTPS Lambda Function URL used by the Salesforce backend. The missing HSTS header is reported on that AWS-managed domain and is not evidence of plaintext transport or authorization bypass.

Reviewer Disposition

The ZAP findings are expected public-form behavior, AWS-managed endpoint header behavior, or informational browser-resource notes. The scans confirm that protected tenant/backend/admin/import-export routes reject unauthenticated requests and that the public prefill/submit endpoints enforce publish-token and form-policy validation.